CHS security checklist - things only people can do

18 October 2026 - fill in owner and date

Why this list exists

The code and database are now locked down and tested. Most remaining risk is people and accounts. Tick each line with a date.

Checklist

#	Action	Owner	Date done
1	Authenticator-app two-step sign-in on Supabase, GitHub, Paystack, Resend, Termii, domain registrar and email accounts	Owner of each account	
2	Each team member has their own login; no shared passwords; password manager for the team	Super admin	
3	Paystack: restrict dashboard roles, turn on transfer approval, IP allow-list if offered, note who can see the secret key	Super admin	
4	Supabase: Point-in-time recovery on, and one test restore into a scratch project	Developer + super admin	
5	Rotate Paystack secret key and Supabase service key at least every 6 months and when anyone with access leaves	Super admin	
6	Review Platform health page and the audit log weekly; acknowledge every security alert	Super admin	
7	Written incident plan: who freezes withdrawals, who calls Paystack, who informs users	Super admin	
8	Data breach duty under the Nigeria Data Protection Act - confirm timelines and registration with a lawyer	Lawyer	
9	Outside penetration test before large money volumes	Super admin	
10	Remove or keep test accounts: decision recorded	Super admin	
11	Resend domain verified; RESEND_FROM set; one real email test	Super admin + developer	
12	Phone check: staff admin phones use screen lock and device encryption	Each staff admin	